

HKUST · Fall 2026/27

Lecture 2

Privacy and Data Protection

MAIE 5103

Instructor: HAN, Sirui
Case-based lecture · 2026/27

Privacy concerns who may collect, infer, use, and
contest personal data.



Learning objectives

By the end of this session, you should be able to:

01 TRACE

Follow personal data from collection through inference, decisions, and retention.

02 APPLY

Use concepts such as purpose limitation, contextual integrity, and minimisation.

03 EVALUATE

Assess privacy harms, power asymmetries, safeguards, and available remedies.

04 DESIGN

Propose privacy controls that combine engineering, rights, and accountability.

The session links data flows to human consequences, governance, and design.

Lecture roadmap

01

Privacy concepts

Definitions, sensitive data, anonymisation

02

Privacy theories

Control, relationships, context, power

03

Data lifecycle

Collection, processing, inference, decisions

04

Four cases

Clearview, Rite Aid, BetterHelp, ChatGPT

05

Rights and governance

GDPR principles, rights, DPIA

06

Privacy engineering

Privacy by Design and PETs

07

Application

Audit activity, debate, design rules

DEFINE



THEORISE



ANALYSE



GOVERN

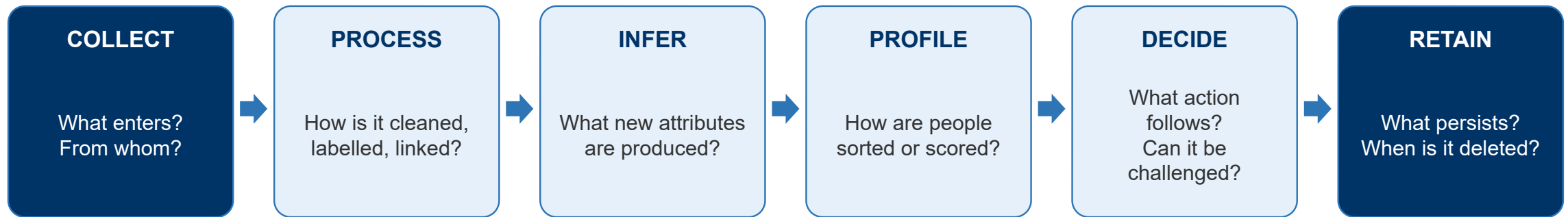


DESIGN

The lecture moves from concepts to cases, then to governance and design.

Privacy and data protection across the AI lifecycle

Privacy risk accumulates as data changes form and purpose.



Three questions at every stage

Purpose and necessity

What goal justifies the data?

Human impact

Who bears the risk?

Rights and remedy

Can people contest it?

A lawful data source does not guarantee a fair inference, decision, or retention practice.

Privacy, data, and power

Concepts and theories for analysing AI
systems

CORE QUESTION

**Who controls how personal data is
collected, inferred, used, and contested?**



Foundations roadmap

6



Opening poll: what data did you share today?

Think for 30 seconds. Name one data point, who collected it, and the likely purpose.

1 LOCATION

GPS, Wi-Fi, transport and proximity signals

2 MESSAGING

Contacts, metadata, content and timing

3 BROWSING

Sites, searches, clicks and device identifiers

4 PAYMENTS

Merchant, amount, time and transaction history

5 HEALTH

Symptoms, appointments, sleep and activity

6 BIOMETRICS

Face, voice, fingerprint and gait

WHO?

WHY?

WHAT FOLLOWS?

Privacy analysis starts by making ordinary data flows visible.

Privacy, data protection, and data security

“The right to be let alone.”

Warren & Brandeis, 1890

Westin’s control account

Individuals seek to determine when, how, and to what extent information about them reaches others.

PRIVACY

What boundaries protect personal life, relationships, identity, and autonomy?

DATA PROTECTION

What rules govern the processing of information about identifiable people?

DATA SECURITY

What safeguards protect confidentiality, integrity, and availability?

One system can be secure yet still violate privacy when it collects too much data or uses it outside the expected context.

These concepts overlap, but each asks a different question.

Control and relational accounts of privacy

CONTROL

Agency: the person controls disclosure and access.

Mechanism: notice, choice, consent, and withdrawal.

Strength: centres autonomy and personal boundaries.

Limit: assumes people can understand and refuse.

RELATIONAL

Relations: privacy depends on roles and expectations.

Responsibility: duties extend across organisations and vendors.

Vulnerability: the ability to refuse is unevenly distributed.

Question: who gains power when data moves?

INDIVIDUAL



RELATIONSHIP



ECOSYSTEM

Control explains individual choice; relational accounts expose power across the data ecosystem.

Privacy risks amplified by AI

01**SCALE**

Models can process billions of records and connect data across services.

**02****INFERENCE**

Systems derive attributes that a person never disclosed directly.

**03****OPACITY**

People often cannot see the model, data lineage, or decision logic.

**04****PERSISTENCE**

Copies, embeddings, profiles, and model behaviour may outlast the original context.



AI can create sensitive knowledge without collecting a sensitive field.

AI changes the scale, depth, visibility, and duration of personal-data processing.

Personal data

“Any information relating to an identified or identifiable natural person.”

GDPR Article 4(1)

DIRECT IDENTIFIERS

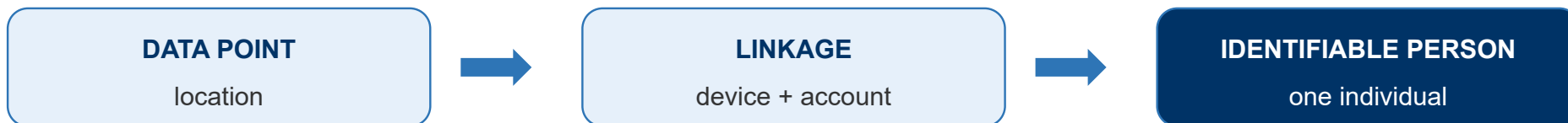
Name or identification number
Email address or account ID
Face image used for identification

INDIRECT IDENTIFIERS

IP address or cookie ID
Location and device fingerprint
Distinctive behavioural patterns

AI-SPECIFIC QUESTIONS

Can records be linked?
Can the model single someone out?
Can an output reveal training data?



Identifiability can arise directly, indirectly, or through linkage with other data.

Special categories of personal data

GDPR Article 9 gives additional protection to data that can create serious risks to rights and freedoms.

1 RACIAL OR ETHNIC ORIGIN

Images, names, language or location may support an inference.

2 POLITICAL OR RELIGIOUS BELIEFS

Likes, subscriptions and movement patterns can reveal affiliations.

3 TRADE UNION MEMBERSHIP

Employment and membership records require special care.

4 GENETIC AND BIOMETRIC DATA

Genomes and biometric templates can identify a person uniquely.

5 HEALTH DATA

Symptoms, searches and service use can reveal health status.

6 SEX LIFE OR SEXUAL ORIENTATION

Behavioural data may expose highly private characteristics.

The risk follows the meaning produced by the system, not only the field originally collected.

AI can infer protected characteristics from data that appears ordinary in isolation.

Anonymisation and pseudonymisation

ANONYMISATION

Goal: prevent identification using means reasonably likely to be used.

Legal effect: genuinely anonymous information falls outside GDPR.

Challenge: rich datasets and outside data can enable linkage.

Irreversible in the relevant context

PSEUDONYMISATION

Method: replace identifiers with tokens, codes, or separate keys.

Legal effect: the information remains personal data.

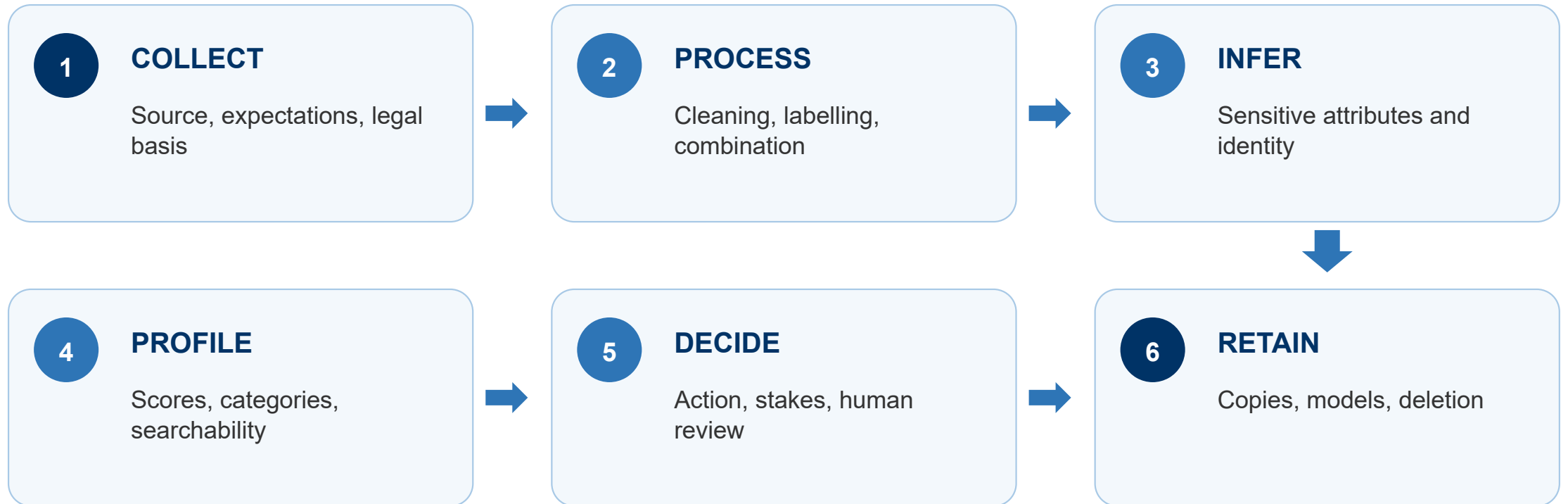
Control: separate the key, restrict access, and document re-linking.

Re-attribution remains possible



Risk reduction depends on whether a person can still be singled out or re-identified.

Privacy questions across the AI lifecycle



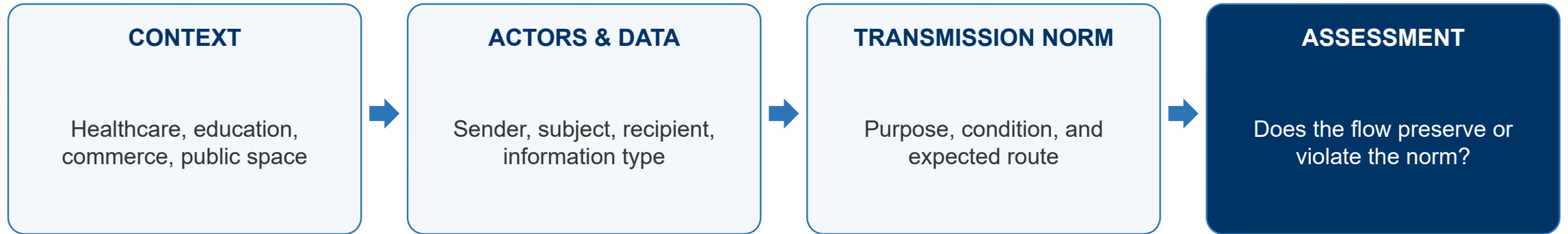
RISK COMPOUNDS

The privacy assessment follows the data, the inferences, and the actions they enable.

Contextual integrity

“Contextual integrity ties adequate protection for privacy to norms of specific contexts.”

Helen Nissenbaum, 2004



A photograph posted for friends does not automatically carry a norm permitting biometric police search.

Privacy depends on whether information follows the norms of its social context.

Applying contextual integrity to AI

EXPECTED FLOW

Hospital → patient record → treatment team

CARE

School → coursework → teacher

ASSESSMENT

CONTEXT CROSSING

Therapy data → advertising profiles **BETTERHELP**

Public photos → biometric database **CLEARVIEW**

Shopping data → credit risk score **PROFILING**

Contextual integrity asks who sent what information to whom, under which condition, and for what purpose.

The central test is whether data crosses a contextual boundary without an appropriate norm.

Surveillance capitalism

“Human experience” becomes raw material for behavioural data.

Shoshana Zuboff, 2019

EXTRACT



capture behaviour

COMMODIFY



create data products

PREDICT



forecast action

INFLUENCE

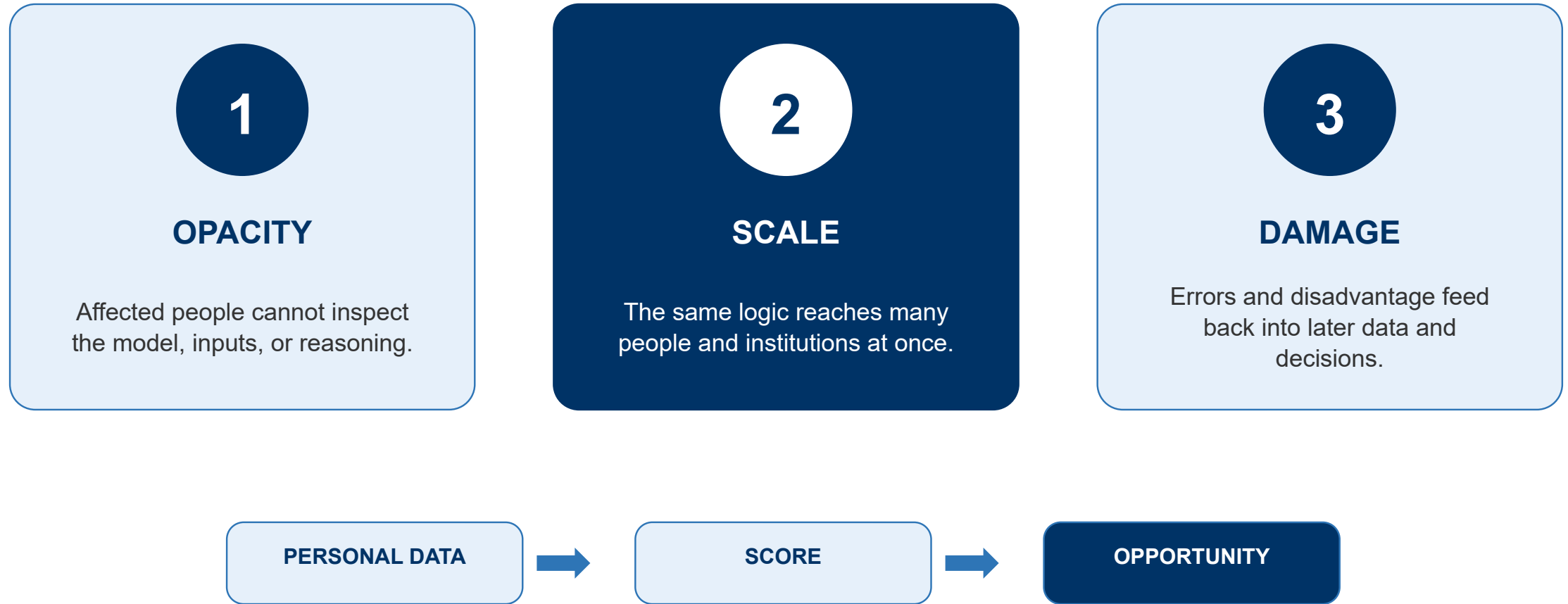


shape choices



Commercial data extraction converts everyday activity into prediction and influence.

Data power in O'Neil's WMD framework



Opacity, scale, and damage explain why some data-driven systems become difficult to resist.

Consent and its limits

VALID CONSENT

INFORMED	The person understands the data and purpose.
FREELY GIVEN	Refusal does not carry an unfair penalty.
SPECIFIC	Consent attaches to defined purposes.
UNAMBIGUOUS	A clear affirmative action expresses agreement.
WITHDRAWABLE	Withdrawal remains as easy as giving consent.

STRUCTURAL LIMITS

NOTICE	long, hidden, or difficult to understand
DEPENDENCE	agree or lose access to a needed service
BUNDLING	one click covers unrelated downstream uses
INFERENCE	the system derives data never disclosed
DOWNSTREAM USE	withdrawal cannot recall every copy

Consent requires a real choice plus controls over later use.

Consent can authorise a specific use, but it cannot correct power asymmetry on its own.

The notice-and-consent problem

NOTICE

Can the person understand the information?

COMMON FAILURE

Long policies, vague purposes, dark patterns

CHOICE

Can the person refuse without losing access?

COMMON FAILURE

Bundled consent and essential services

CONTROL

Can the person see and stop downstream use?

COMMON FAILURE

Vendors, data brokers, models, copies

Effective privacy protection also needs purpose limits, minimisation, oversight, and enforceable rights.

Individual choices cannot govern a data ecosystem that people cannot observe.

A taxonomy of privacy harms

INFORMATION COLLECTION

Surveillance
Interrogation

Clearview: collection at scale

INFORMATION PROCESSING

Aggregation · Identification
Insecurity · Secondary use · Exclusion

ChatGPT: aggregation and reuse

INFORMATION DISSEMINATION

Disclosure · Exposure
Distortion · Appropriation

BetterHelp: disclosure to ad platforms

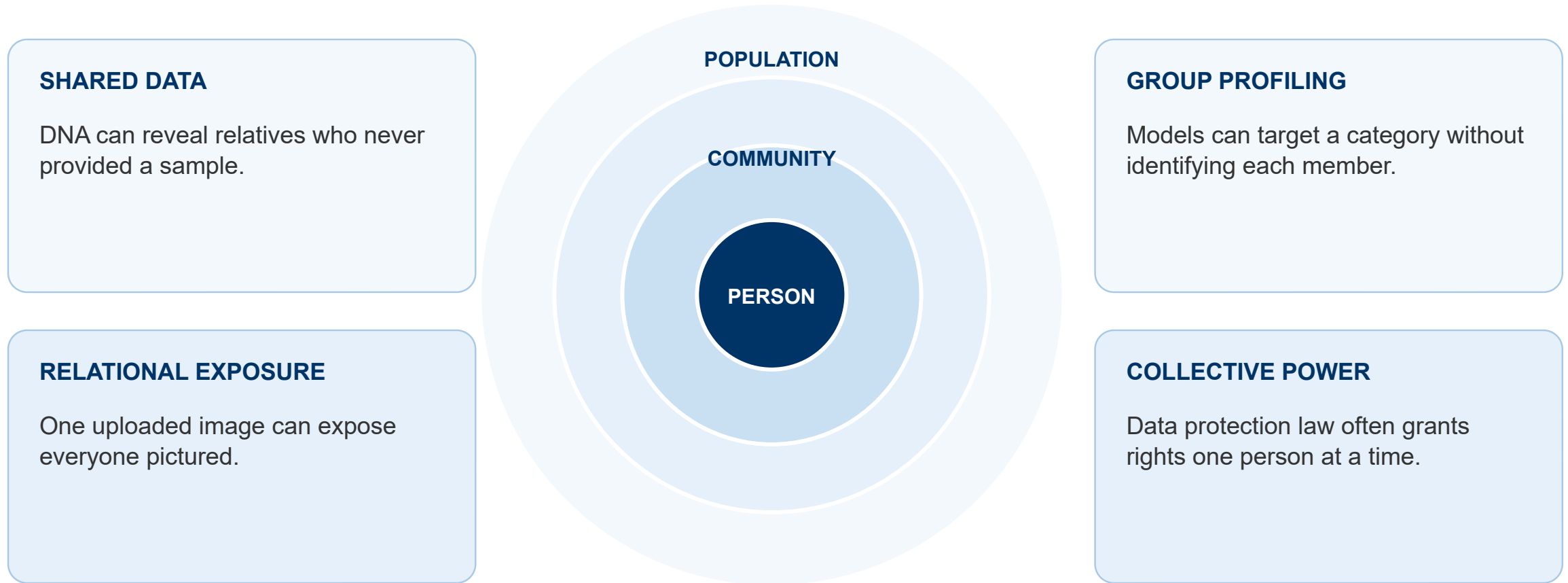
INVASION

Intrusion
Decisional interference

Rite Aid: confrontation after a false match

Privacy harm can enter through collection, processing, dissemination, or intrusion.

Group privacy and relational harms



An individual opt-out may not protect the group created by the model.

AI systems can affect families, communities, and populations without naming every individual.

Privacy and vulnerability in the digital poorhouse

Automated public services can become systems that profile, police, and punish people seeking help.

OPACITY

People cannot understand the model.

SCALE

Automated rules affect many cases.

DAMAGE

Errors can remove essential support.

INEQUALITY

Refusal is easiest for those with alternatives.



Privacy burdens increase when people cannot refuse data collection or leave the system.

Three systems in the digital poorhouse

INDIANA

Benefits eligibility

Automation introduced procedural barriers and widespread denials. Online processes also disadvantaged households with limited access.

ALLEGHENY COUNTY

Child welfare screening

A predictive score combines administrative data to help screen referrals for investigation.

LOS ANGELES

Homelessness services

Coordinated-entry systems collect extensive personal data to prioritise scarce housing assistance.

MANDATORY DATA



CONTEXT LINKAGE



LIMITED RECOURSE

Across benefits, child welfare, and homelessness services, data collection can become a condition of support.

Data collection without meaningful recourse

WHAT SYSTEMS MAY COLLECT

Income and employment
Family composition
Health and mental-health history
Justice and child-welfare records
Housing status and service use

WHAT PEOPLE MAY LACK

Clear notice about downstream use
Access to the score or model logic
A way to correct inaccurate records
Human review with authority to override
A service option that requires less data

The ethical issue combines privacy loss, dependency, and weak contestability.

Essential services can make refusal impractical while offering few ways to correct or challenge data.

WMDs as self-reinforcing privacy systems

1 OPACITY

College ranking

Inputs and gaming strategies remain hidden.

2 SCALE

Teacher evaluation

A common model can affect careers across institutions.

3 DAMAGE

Predictive policing

Recorded arrests guide patrols, which produce more recorded arrests.

COLLECT

historic records



SCORE

risk prediction



ACT

allocate scrutiny



REINFORCE

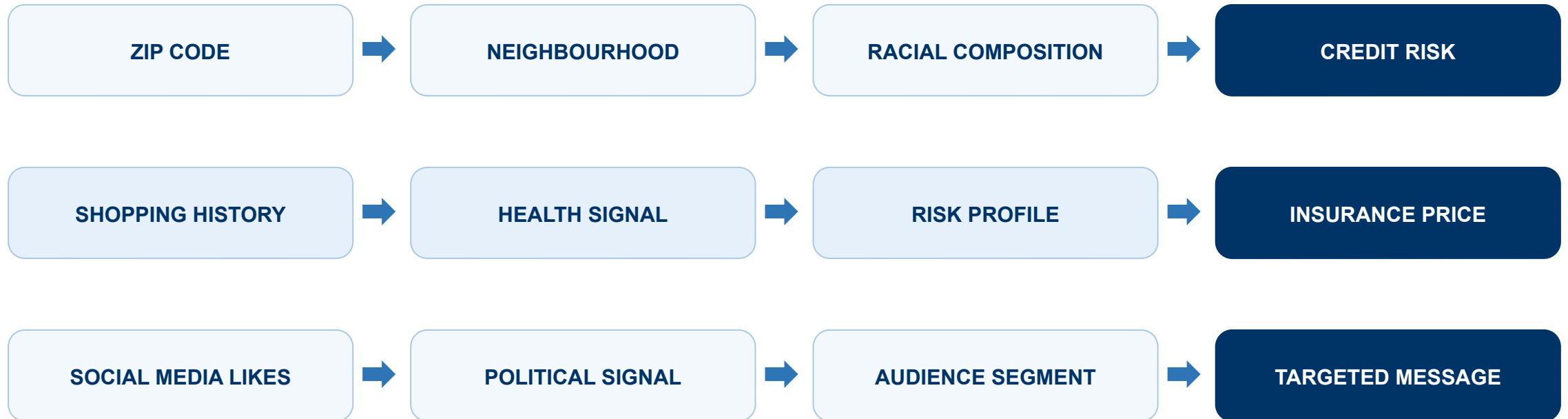
new records

Feedback turns yesterday's surveillance into tomorrow's justification.

A model becomes more dangerous when opaque scores guide action and the resulting data reinforce the score.

Proxy variables and inferred privacy

Proxy variable: an observable measure used in place of a characteristic that is unavailable, sensitive, or prohibited.



A neutral-looking input can stand in for a protected or highly sensitive characteristic.

Fair Information Practice Principles

**1 COLLECTION
LIMITATION**

Set limits and use lawful, fair collection.

2 DATA QUALITY

Keep data relevant, accurate, complete, and current.

**3 PURPOSE
SPECIFICATION**

State the purpose no later than collection.

4 USE LIMITATION

Restrict disclosure and incompatible secondary use.

**5 SECURITY
SAFEGUARDS**

Protect against loss and unauthorised access.

6 OPENNESS

Make policies and practices visible.

**7 INDIVIDUAL
PARTICIPATION**

Enable access, correction, and challenge.

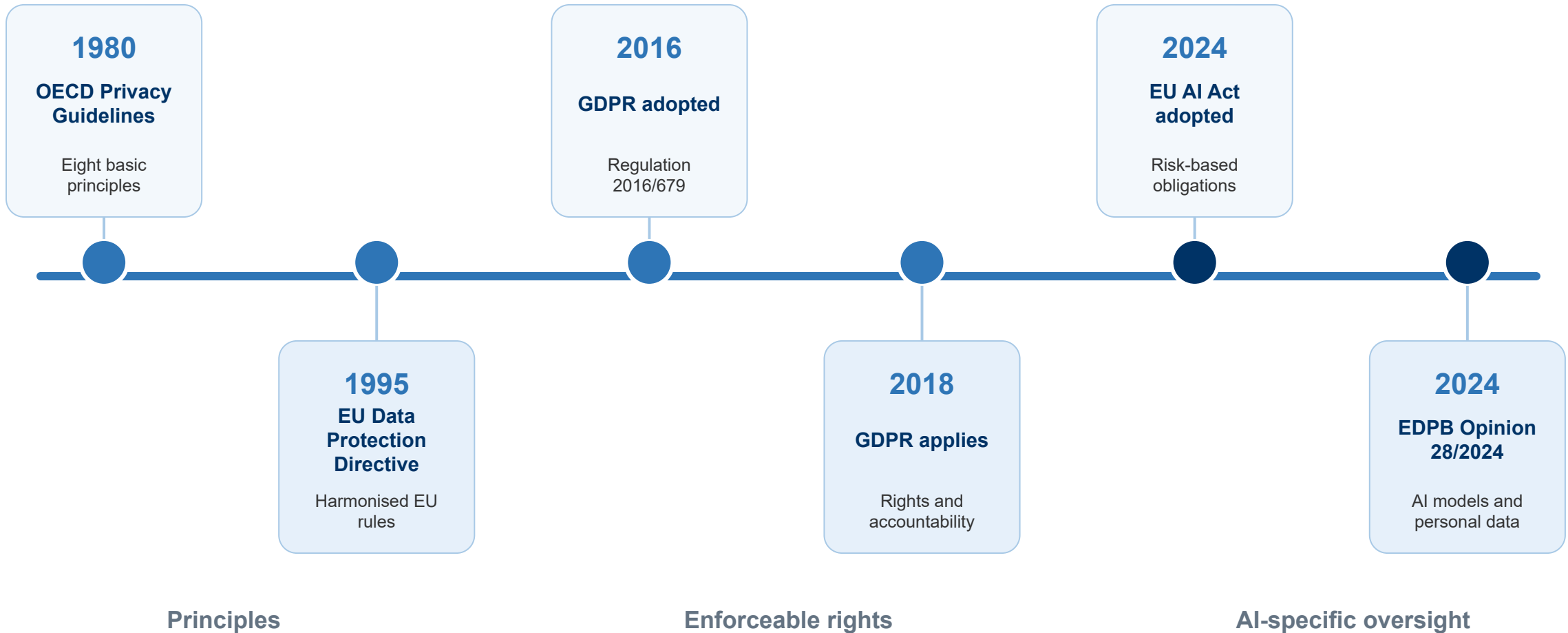
8 ACCOUNTABILITY

Hold the controller responsible for compliance.

1980 OECD Guidelines

The OECD's eight principles established a durable foundation for modern data protection.

From FIPPs to AI governance



Data protection evolved from general principles to enforceable rights and AI-specific oversight.

BREAK

Who holds power over your data?

Name one AI system that collects your data. What could you inspect, correct, delete, or contest today?

15–20 MINUTES

From theory to cases

FOUNDATIONS

Definitions: privacy, data protection, and security

Legal concepts: personal data and special categories

Theories: control, relationships, and contextual integrity

Power: surveillance capitalism and vulnerability

Lifecycle: collection through retention and deletion

CASE STUDIES

CLEARVIEW AI → public photos to biometric search

RITE AID → false match to physical confrontation

BETTERHELP → therapy data to advertising

CHATGPT → training data, outputs, and rights

DATA DECISION



HUMAN HARM



REMEDY

Theories provide the questions; cases show the stakes and the available remedies.

Key definitions recap

1 PERSONAL DATA

Information relating to an identifiable person.

2 SPECIAL CATEGORY DATA

Protected data such as health or biometric identity.

3 CONTEXTUAL INTEGRITY

Information flows should follow contextual norms.

4 SURVEILLANCE CAPITALISM

Behaviour becomes data for prediction and influence.

5 WMD

An opaque, scalable model that produces damaging outcomes.

6 DIGITAL POORHOUSE

Automated systems that intensify surveillance of people seeking support.

Use the vocabulary to identify the data flow, power relation, harm, and remedy.

These concepts will recur in every case and governance discussion.

Four privacy harms in practice

Each case connects a data decision to a human consequence and a regulatory response.

CLEARVIEW

RITE AID

BETTERHELP

CHATGPT

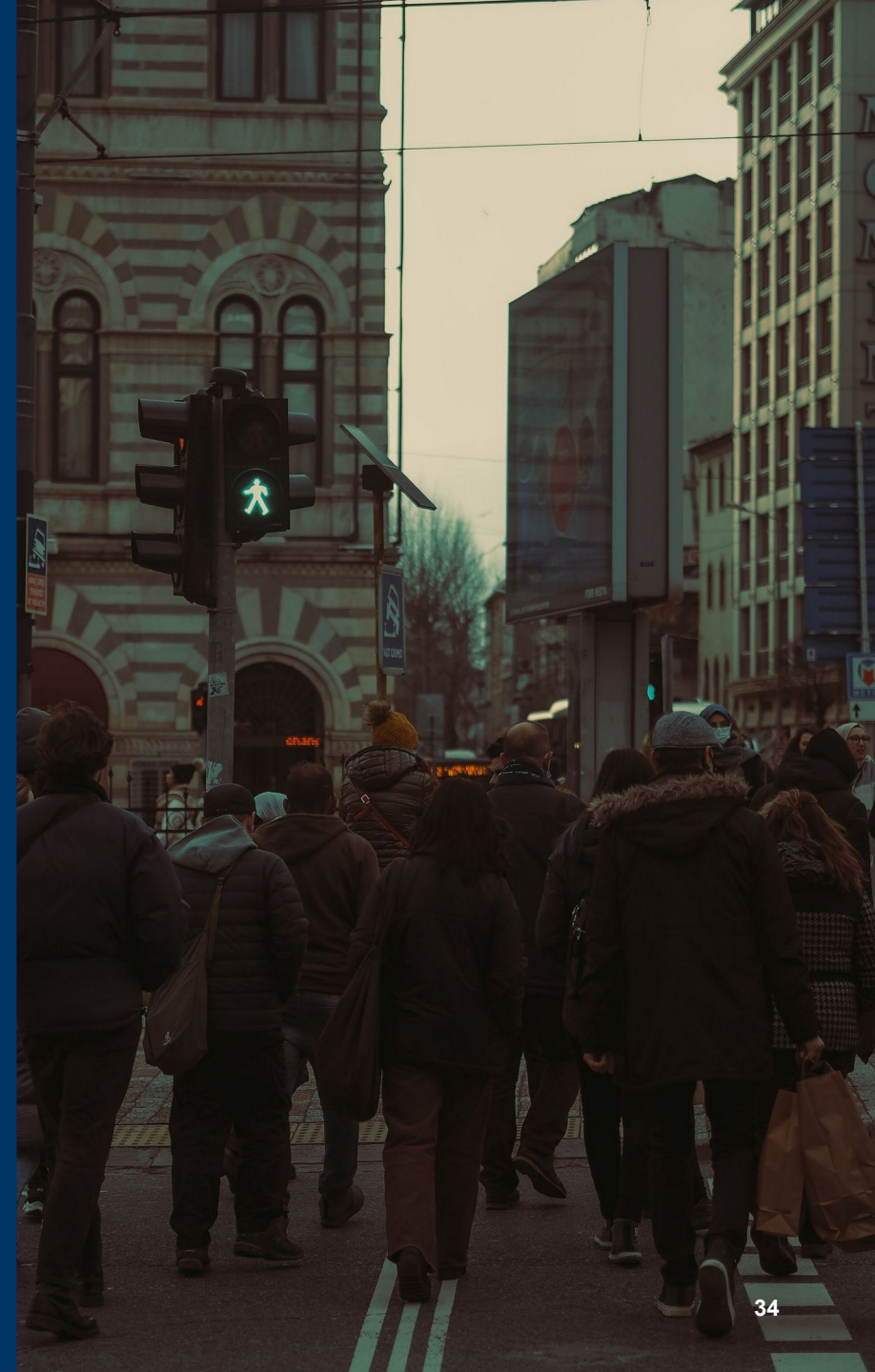


Clearview AI

CORE QUESTION

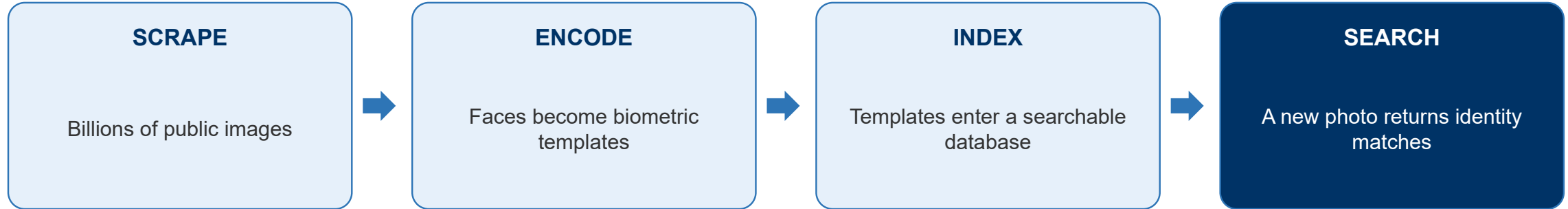
Can public photographs become a global biometric identification database?

Each case links a data decision to a human consequence and a remedy.



Case 1: what happened

A public photograph entered a new system with a new purpose and much greater power.



WHO ENTERED THE DATABASE?

People whose images appeared on websites and social media. Most had no notice, consent, or practical relationship with Clearview.

WHO RECEIVED SEARCH POWER?

Customers included law enforcement bodies. The service turned scattered photographs into a commercial identity search tool.

Clearview treated public visibility as permission for an unrelated biometric purpose.

The privacy harm is created by transformation



PERSISTENT IDENTIFIER

A face template can support repeated identification.

CONTEXT COLLAPSE

Separate websites become one identity graph.

OBSERVATION AT SCALE

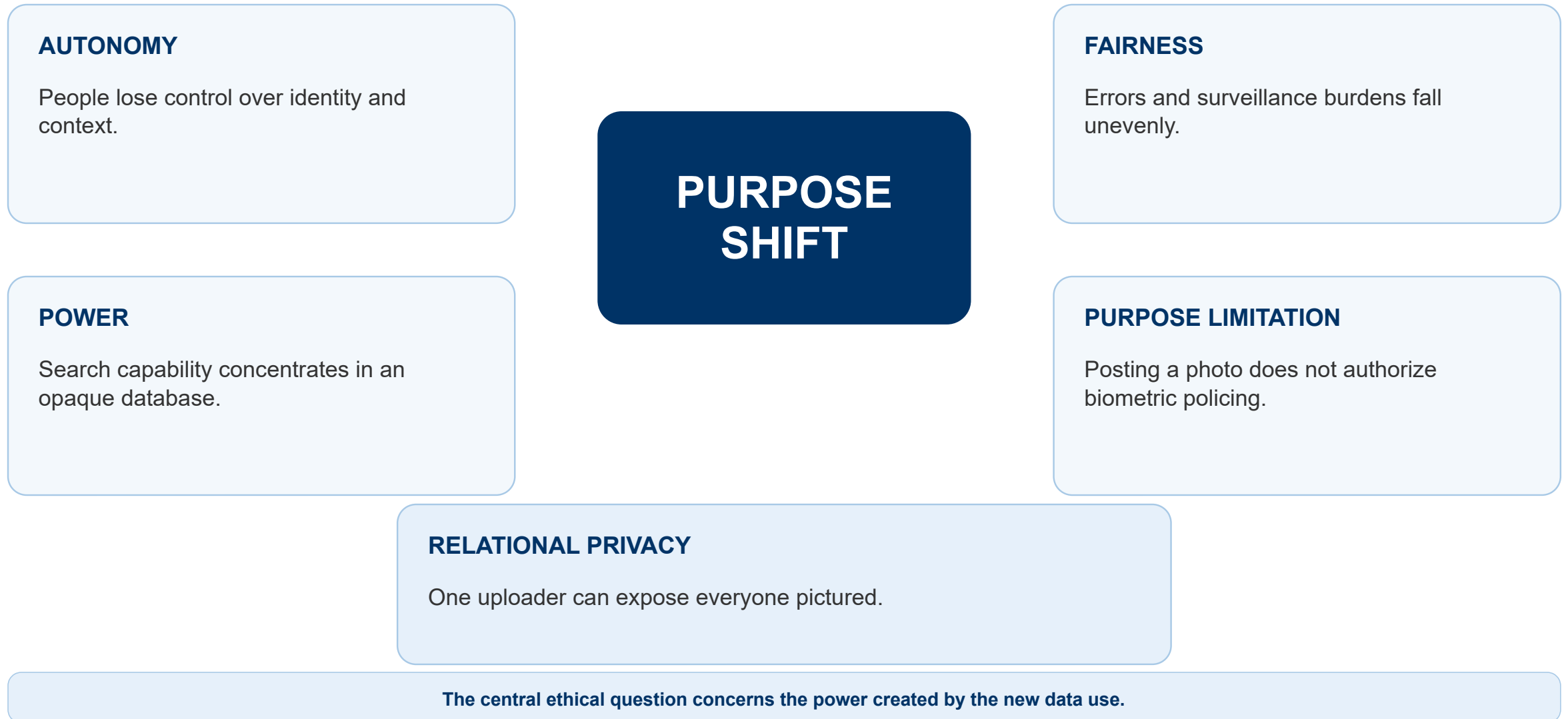
A search can locate someone across time and platforms.

DIFFICULT DELETION

Images, templates, and derived systems may persist.

A photograph becomes infrastructure for persistent identification across contexts.

Ethical analysis: consent is not the only issue



Discussion: design the boundary

Does public accessibility reduce a reasonable expectation of privacy? Why?

2 FOLLOW-UP

Is opt-out meaningful when the person never knew collection occurred?

3 FOLLOW-UP

Should law-enforcement access lower the ethical standard or raise it?

4 FOLLOW-UP

What would a proportionate, purpose-limited facial-search service require?

5 FOLLOW-UP

Which remedy matters most: notice, deletion, access limits, or a ban?

Use the question to identify a boundary, a safeguard, and a remedy.

A defensible boundary must address purpose, access, retention, and meaningful recourse.

Outcome and lesson

€20M

FRANCE · 2022

CNIL ordered Clearview to stop unlawful collection and use, and to delete data concerning people in France.

£7.5M

UNITED KINGDOM · 2022

The ICO issued a fine and enforcement notice. Later litigation focused on jurisdiction and scope.

2025

UPPER TRIBUNAL

The tribunal upheld key ICO jurisdiction grounds and returned the substantive appeal for determination.

Update: permission to appeal the Upper Tribunal decision was granted in December 2025.

Web scraping does not remove purpose limitation, legal basis, or data-subject rights.

CASE 2 · PRIVACY IN PRACTICE

Rite Aid

CORE QUESTION

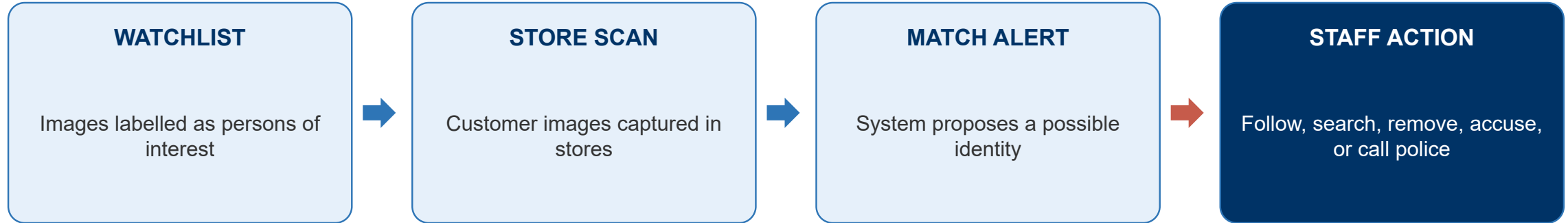
When an inaccurate face match becomes an accusation in a physical store.

Each case links a data decision to a human consequence and a remedy.



Case 2: deployment without guardrails

Rite Aid used facial-recognition surveillance in hundreds of stores from 2012 to 2020.

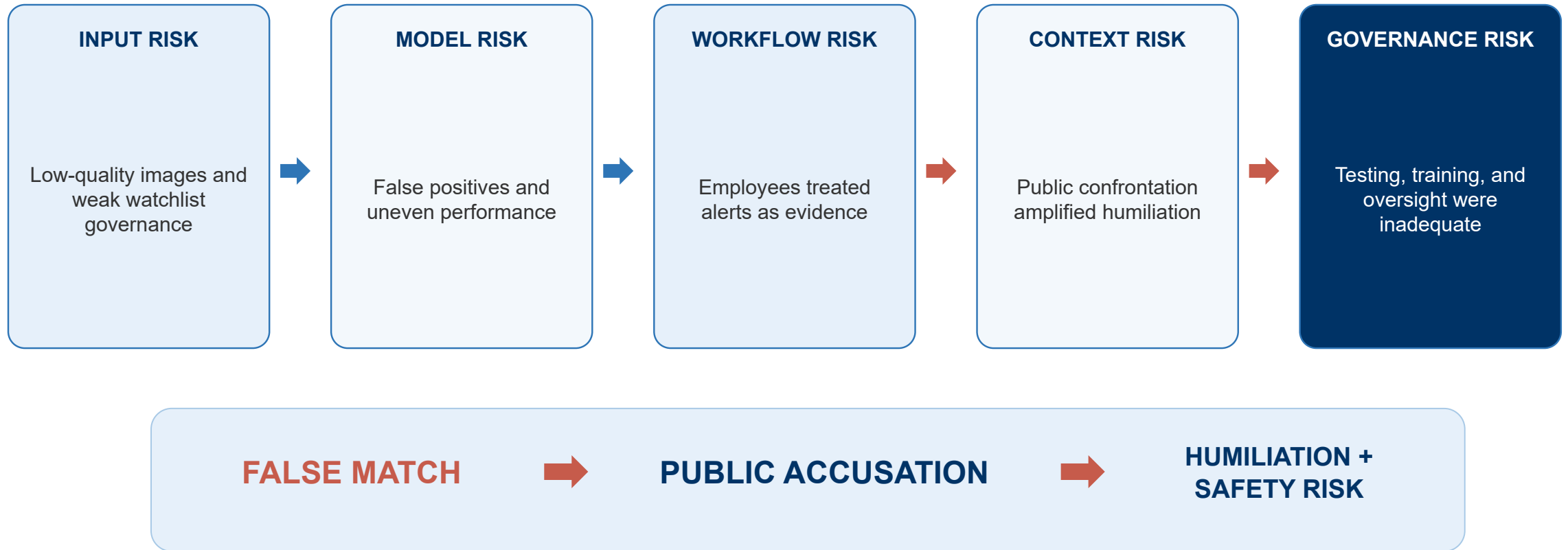


NO MEANINGFUL NOTICE

Customers generally did not know that facial recognition was operating. Employees could treat alerts as evidence rather than uncertain signals.

A probabilistic alert entered a workflow that could confront and remove a customer.

A technical error became a social harm



The harm emerged from the model, the workflow, and the context of intervention.

Ethical analysis: accuracy is necessary, not sufficient

HIGH STAKES

A statistically accurate system can remain unjust when safeguards are weak.

ASYMMETRIC COST

The retailer saves time. The shopper bears stigma and confrontation.

COERCIVE SETTING

Notice cannot cure surveillance when opting out means avoiding the store.

AUTOMATION BIAS

Human review fails when staff see only an alert and trust it.



FTC allegations also described disproportionate impact on people of color.

High-stakes deployment requires safeguards that address who bears the cost of error.

Discussion: should this system be deployed?

What evidence threshold should precede an employee intervention?

2 FOLLOW-UP

Who should be allowed onto a watchlist, and for how long?

3 FOLLOW-UP

Which metrics require testing across demographic groups and store contexts?

4 FOLLOW-UP

Is a human in the loop a safeguard if the human sees only the alert?

5 FOLLOW-UP

Would a less intrusive alternative achieve the security objective?

Use the question to identify a boundary, a safeguard, and a remedy.

Deployment should proceed only if evidence, safeguards, and remedy match the stakes.

Outcome and lesson

5

YEAR BAN

Facial-recognition
surveillance

DELETE

Photos, videos, and derived data, models, or algorithms

MONITOR

Risk assessment, testing, training, notice, and complaint handling

STOP IF UNSAFE

Future biometric systems require controls that prevent foreseeable harm

Privacy by design includes deployment workflow, error response, vendor control, and remedy.

BetterHelp

CORE QUESTION

What happens when therapy-seeking data enters the advertising ecosystem?

Each case links a data decision to a human consequence and a remedy.



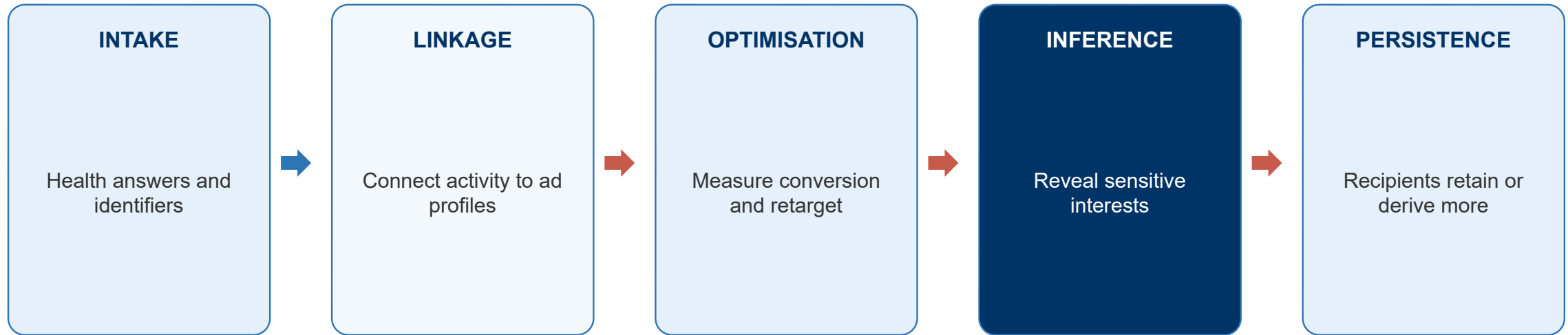
Case 3: sensitive data beyond the clinic

People seeking online counselling supplied data that strongly implied a health context.



The case concerns a contested business use of vulnerable-context data, not only security.

The hidden data flow



A visit, an identifier, or a questionnaire response can become a sensitive signal when combined with an advertising profile.

Identifiers and advertising tools can expose health interests without sharing a clinical record.

Ethical analysis: context defines reasonable use

THERAPY-SEEKING CONTEXT

Expected flow: person → counselling service → care



ADVERTISING CONTEXT

Contested flow: person → service → advertising profile

CONTEXTUAL INTEGRITY

Therapy data carries stronger expectations than ordinary shopping data.

CONSENT

Advertising was not necessary for counselling.

VULNERABILITY

Stigma and chilling effects can follow exposure.

FIDUCIARY EXPECTATION

Users may treat the platform like a care relationship.

Advertising attribution does not establish necessity for sensitive data processing.

Discussion: can consent legitimize this sharing?

What would affirmative express consent need to show here?

2 FOLLOW-UP

Should some data uses remain prohibited even if a user clicks agree?

3 FOLLOW-UP

Where does responsibility sit: service, ad platform, analytics vendor, or all?

4 FOLLOW-UP

How should teams test whether an identifier functions as health data?

5 FOLLOW-UP

Which product metrics could replace person-level advertising attribution?

Use the question to identify a boundary, a safeguard, and a remedy.

The discussion concerns legitimate purpose and responsibility across the data ecosystem.

Outcome and lesson

\$7.8M

PAYMENT

Partial refunds for consumers

AD BAN

USE LIMIT

No sharing of health data for advertising

≈800K

REFUND NOTICES

Consumers notified in 2024

The order also restricted retargeting, required a privacy program, directed deletion by recipients, and mandated independent assessments.

Sensitive data can move through identifiers and advertising infrastructure without a clinical record.

ChatGPT in Italy

CORE QUESTION

How should data-protection law apply to training, probabilistic outputs, and user rights?

Each case links a data decision to a human consequence and a remedy.



Case 4: a generative-AI privacy test

30 MAR 2023

Temporary limitation

Italy's Garante restricted ChatGPT-related processing.

APR 2023

Remedial measures

OpenAI added information, rights, and age-related measures.

28 APR 2023

Service resumed

ChatGPT became available again in Italy.

CONCERNS

Legal basis

Transparency

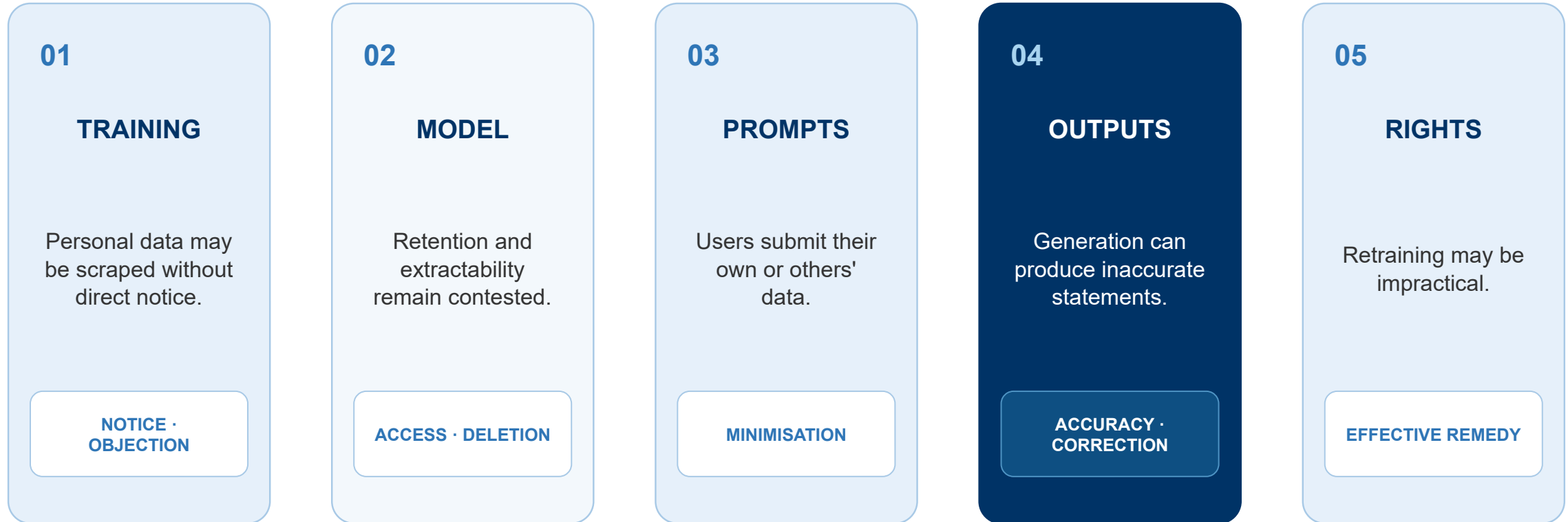
Inaccurate personal data

Reported breach

Age protections

The intervention treated the model as part of a continuing personal-data lifecycle.

Why generative AI complicates data rights



Data-subject rights must operate across training data, model behaviour, prompts, and outputs.

Ethical analysis: innovation does not reverse accountability

LAWFULNESS

Each processing stage needs a defensible basis.

FAIRNESS

Responsibility cannot shift to people who type prompts.

TRANSPARENCY

People need understandable information about sources, purposes, uncertainty, and rights.

ACCURACY

A warning about hallucinations does not repair reputational harm.

CHILDREN

Age-appropriate design forms part of privacy protection.

Technical difficulty does not remove the requirement to design effective rights mechanisms.

A new technical architecture changes implementation, not the duty to protect people.

Discussion: what is a meaningful remedy?

Can model outputs about a person be corrected, or only filtered?

2 FOLLOW-UP

When is legitimate interest a credible basis for model training?

3 FOLLOW-UP

If individual notice is impractical at scale, which substitutes are adequate?

4 FOLLOW-UP

How should developers respond to an objection when retraining is impractical?

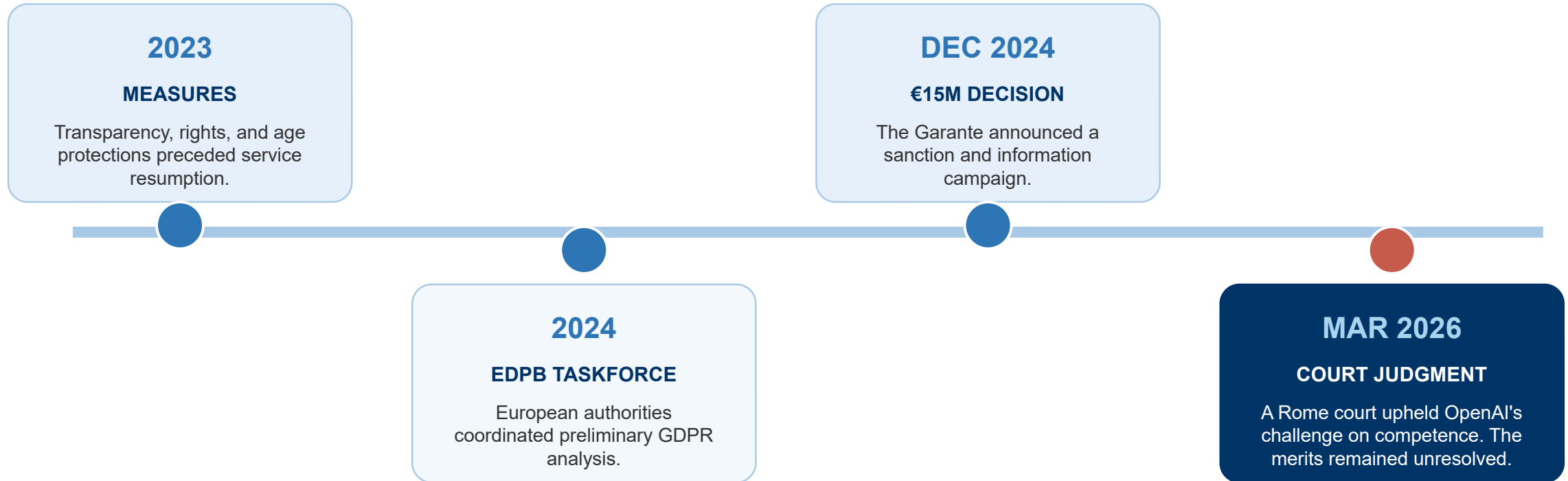
5 FOLLOW-UP

When is temporary suspension proportionate to uncertainty and risk?

Use the question to identify a boundary, a safeguard, and a remedy.

A meaningful remedy must reach the data, the output, and the continuing processing operation.

Outcome, caveat, and lesson



An annulled decision is not an acquittal on the substance of the privacy concerns.

Accountability includes the remedy, the appeal, and the legal uncertainty that follows.

Cross-case synthesis: common patterns

CASE	LIFECYCLE STAGE	KEY HARM	REMEDY
Clearview AI	COLLECT	Public photos become biometric identity infrastructure	€20M CNIL fine and deletion order
Rite Aid	DECIDE	False match leads to accusation in a store	Five-year ban, deletion, and monitoring
BetterHelp	DISSEMINATE	Therapy-seeking data enters advertising systems	\$7.8M payment, ad ban, and assessments
ChatGPT	INFER + OUTPUT	Inaccurate personal data and difficult rights implementation	Transparency, age, and rights measures

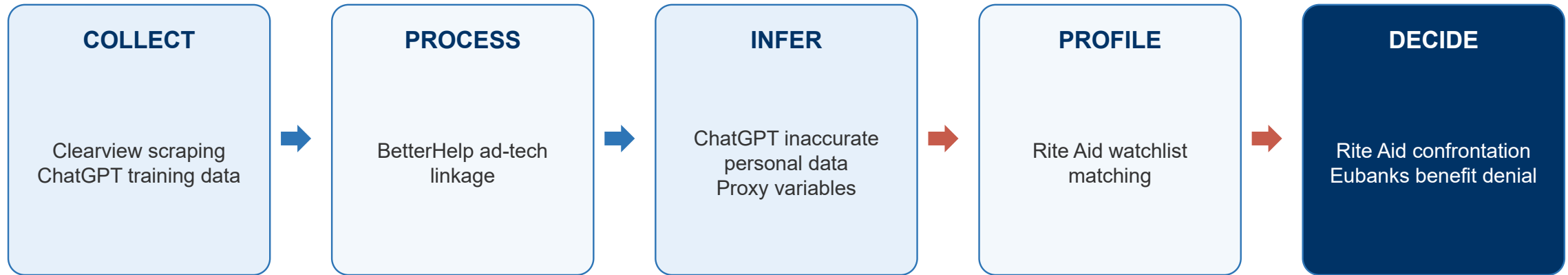
OPACITY

POWER ASYMMETRY

ABSENT RECOURSE

Each case fails at a different stage, yet opacity, power asymmetry, and weak recourse recur.

Cross-case synthesis: where harm enters the lifecycle



RISK COMPOUNDS



An early collection decision can enable later inference, profiling, and consequential action.

Privacy controls must operate across the whole lifecycle because harm at one stage enables the next.

Cross-case synthesis: regulatory responses compared

JURISDICTION	AUTHORITY	INSTRUMENT	KEY OUTCOME
France	CNIL	GDPR	€20M Clearview penalty and deletion order
United Kingdom	ICO + tribunals	UK GDPR	£7.5M Clearview notice; jurisdiction grounds upheld in 2025, appeal continuing
United States	FTC	FTC Act §5 and consent orders	Rite Aid ban and BetterHelp payment, use limits, deletion, and monitoring
Italy / EU	Garante + EDPB	GDPR	ChatGPT measures; €15M decision annulled in 2026 on competence, merits unresolved

Shared principle: organisations must make data power accountable and contestable.

Different legal instruments converge on accountability, use limits, deletion, and rights.

REFLECTION

Which lifecycle stage would you regulate first?

What would your design rule be?

10–15 MINUTES

Next: governance, rights, and privacy design

From remedy to prevention

Rights, frameworks, and technologies

**How can teams prevent privacy failures
while designing an AI system?**

Cases explain failure. Governance and design shape a different outcome.



The GDPR: seven principles

LAWFULNESS, FAIRNESS, TRANSPARENCY

A valid basis, fair effects, and clear information

PURPOSE LIMITATION

Defined purposes and compatible reuse

DATA MINIMISATION

Only data necessary for the purpose

ACCURACY

Correct records and timely rectification

STORAGE LIMITATION

Retention tied to a justified need

INTEGRITY & CONFIDENTIALITY

Security against loss and unauthorised access

ACCOUNTABILITY

Evidence that the controller complies

Article 5(2): the controller must be able to demonstrate compliance.

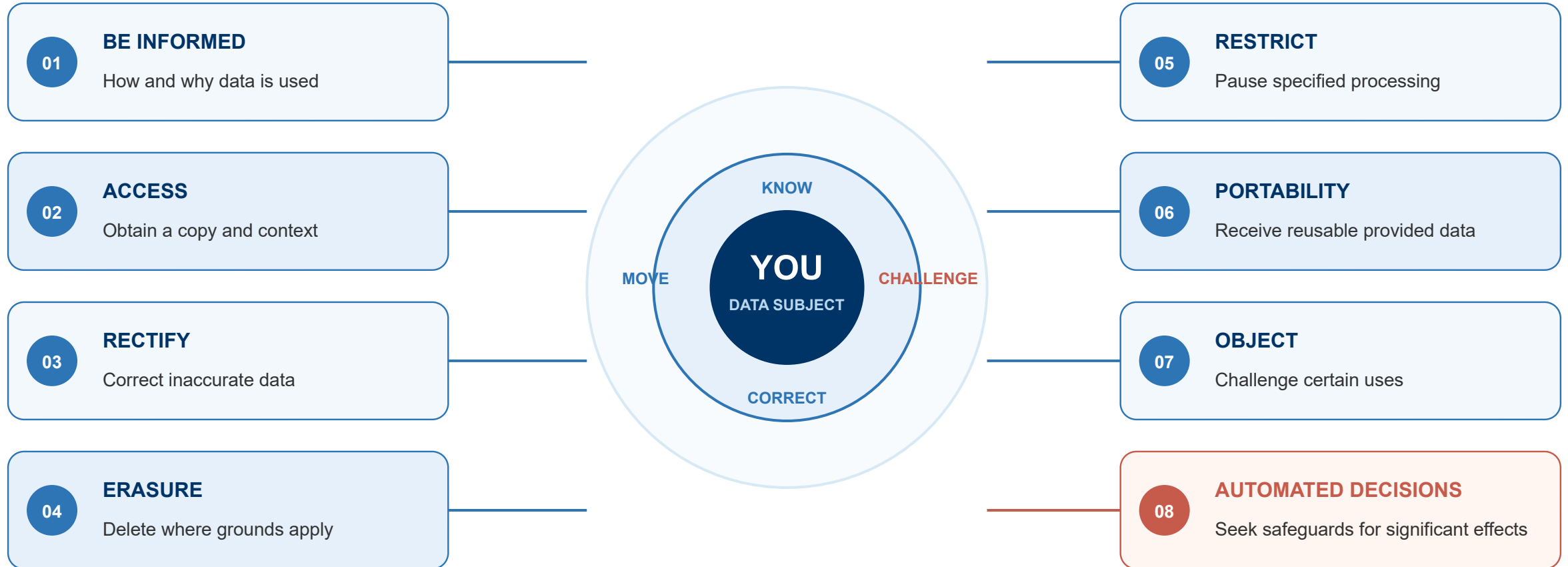
Article 5 makes privacy duties continuous across the AI lifecycle.

GDPR principles in AI systems

PRINCIPLE	WHAT IT REQUIRES IN AN AI SYSTEM
Lawfulness	A defensible basis for collection, training, inference, and deployment
Purpose limitation	A compatibility test before reusing data for model development
Data minimisation	The least personal data and features needed for the stated purpose
Accuracy	Ways to correct source records and personal outputs
Storage limitation	Retention rules for datasets, prompts, logs, and derived data
Security	Protection for data, model access, interfaces, and outputs
Accountability	Data lineage, documented tests, decisions, and rights responses

The principles cover training, model behaviour, prompts, and outputs.

Data subject rights: a control compass



Rights turn a person from a data source into an active participant with claims and remedies.

Access, rectification, and erasure

ACCESS · ART. 15

What data do you hold about me?

AI challenge

Training records and model traces may be difficult to locate.

RECTIFICATION · ART. 16

This information is wrong.

AI challenge

A correction may need to reach source data, profiles, and future outputs.

ERASURE · ART. 17

Delete my data where the legal conditions apply.

AI challenge

Removal from datasets differs from removing influence from a trained model.

The organisation needs a response path for data, model behaviour, and future use.

AI systems must translate database rights into workable model procedures.

Portability, objection, and automated decisions

PORTABILITY · ART. 20

A usable copy

The right concerns data a person provided and processing based on consent or contract. It does not automatically expose a model.

OBJECTION · ART. 21

A reason to stop

The controller must assess the objection against its grounds for continuing the processing.

AUTOMATED DECISIONS · ART. 22

A real safeguard

For solely automated decisions with legal or similarly significant effects, safeguards may include human intervention and challenge.

A nominal human reviewer does not guarantee a meaningful review.

The rights implementation gap

LEGAL CLAIM

SYSTEM REALITY

Show me my data



Training records may lack stable links to individuals

Correct what is wrong



The model may reproduce errors probabilistically

Delete my data



Dataset deletion and model influence are different problems

Stop using my data



A deployed model may continue to encode learned patterns

DESIGNABLE REMEDY

The legal right remains; technical architecture determines whether it works in practice.

Legal bases for processing

CONSENT

Real choice and a clear, specific purpose

CONTRACT

Necessary to deliver the requested service

LEGAL OBLIGATION

Processing required by law

VITAL INTERESTS

Protection of life in a narrow situation

PUBLIC TASK

Official authority or public-interest task

LEGITIMATE INTERESTS

Purpose, necessity, and balancing tests

AI QUESTIONS

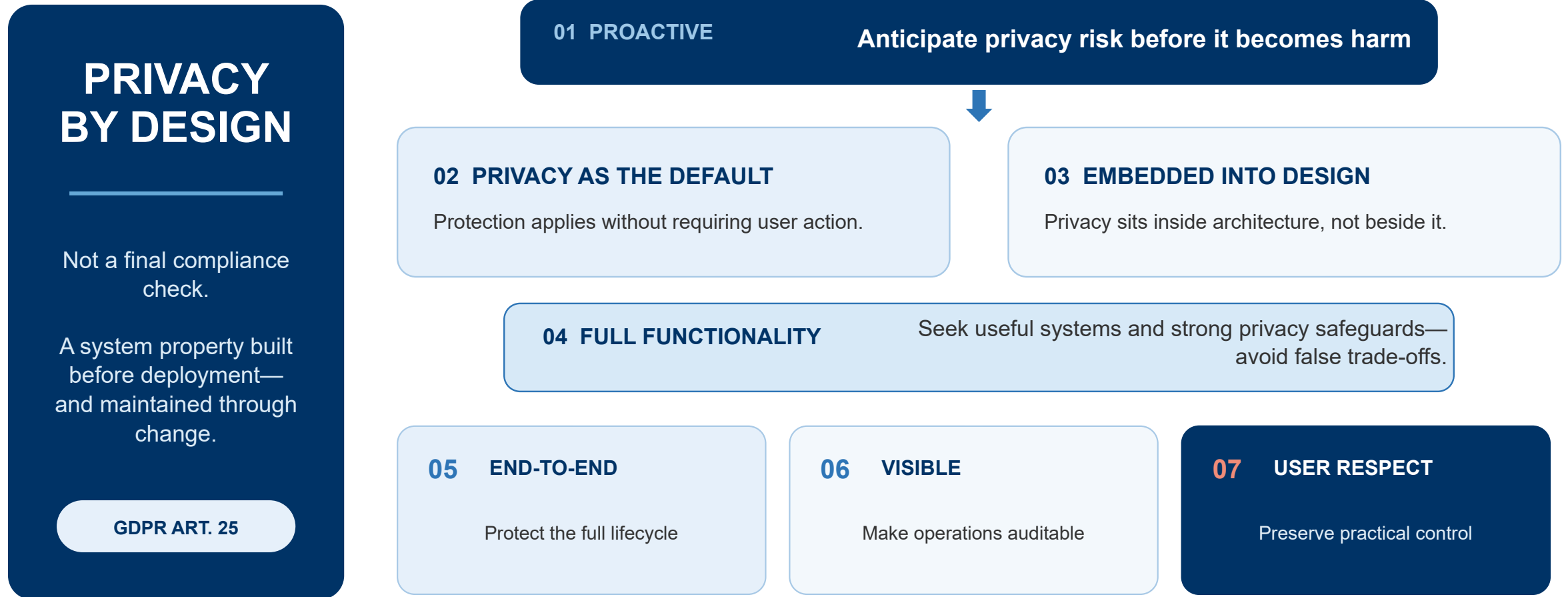
Training data: What basis covers collection and development?

Deployment: Does the new use match what people could reasonably expect?

Special categories: Article 9 requires an additional condition.

Each processing purpose needs a basis that fits the actual relationship and risk.

Privacy by Design: an operating architecture



Privacy by Design is an architecture of defaults, controls, evidence, and user agency.

Privacy by Design in AI

PROACTIVE



Models change through updates, new data, and changed use

DEFAULT



Training pipelines often retain more data than the purpose needs

EMBEDDED



Removing one person's influence may require specialised methods

END TO END



Datasets, model access, prompts, logs, and outputs all need controls

VISIBLE



Opacity makes audit evidence harder to produce

USER RESPECT



Rights need interfaces, identity checks, and response procedures

AI architecture must support privacy requirements after deployment as well as before it.

Privacy-enhancing technologies

DIFFERENTIAL PRIVACY

Noise limits what an output reveals about one person

FEDERATED LEARNING

Training occurs where data resides

SYNTHETIC DATA

Artificial records approximate useful patterns

HOMOMORPHIC ENCRYPTION

Computation runs on encrypted values

SECURE MULTI-PARTY COMPUTATION

Parties compute jointly without pooling raw data

TRUSTED EXECUTION ENVIRONMENTS

Hardware isolates sensitive computation

RAW DATA



SELECTED PET



LIMITED DISCLOSURE

PETs address different threats and often work best in combination.

Differential privacy

CORE IDEA

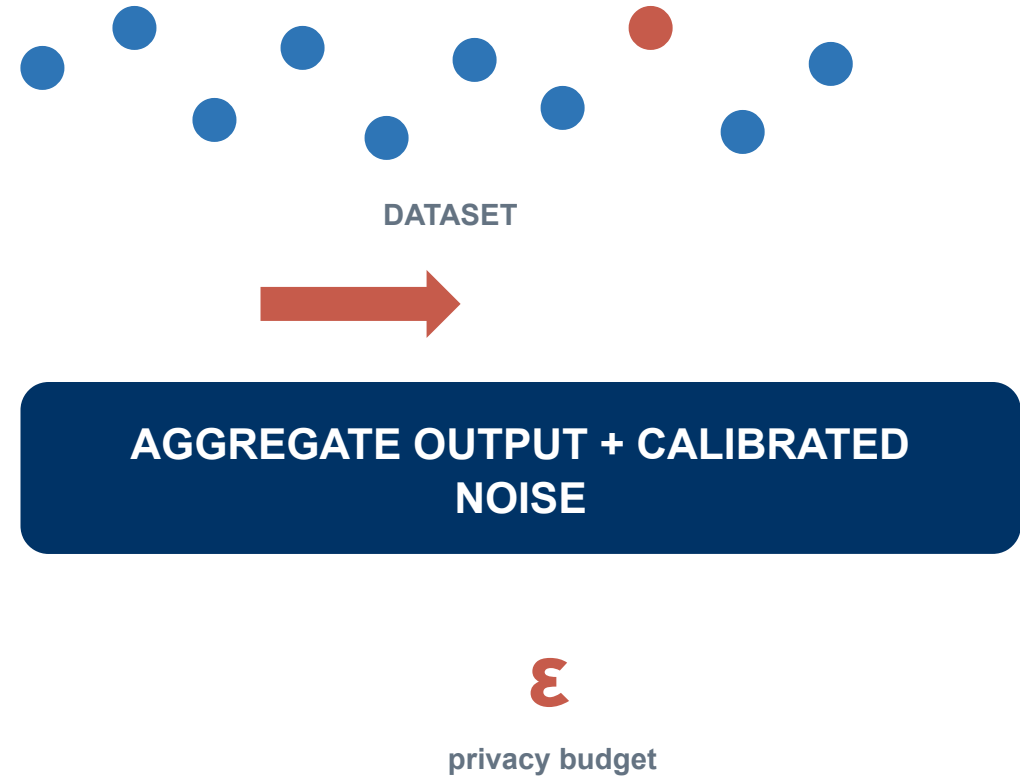
The output changes only slightly when one person's record enters or leaves the dataset.

STRENGTH

A mathematical guarantee supports auditing and composition across repeated queries.

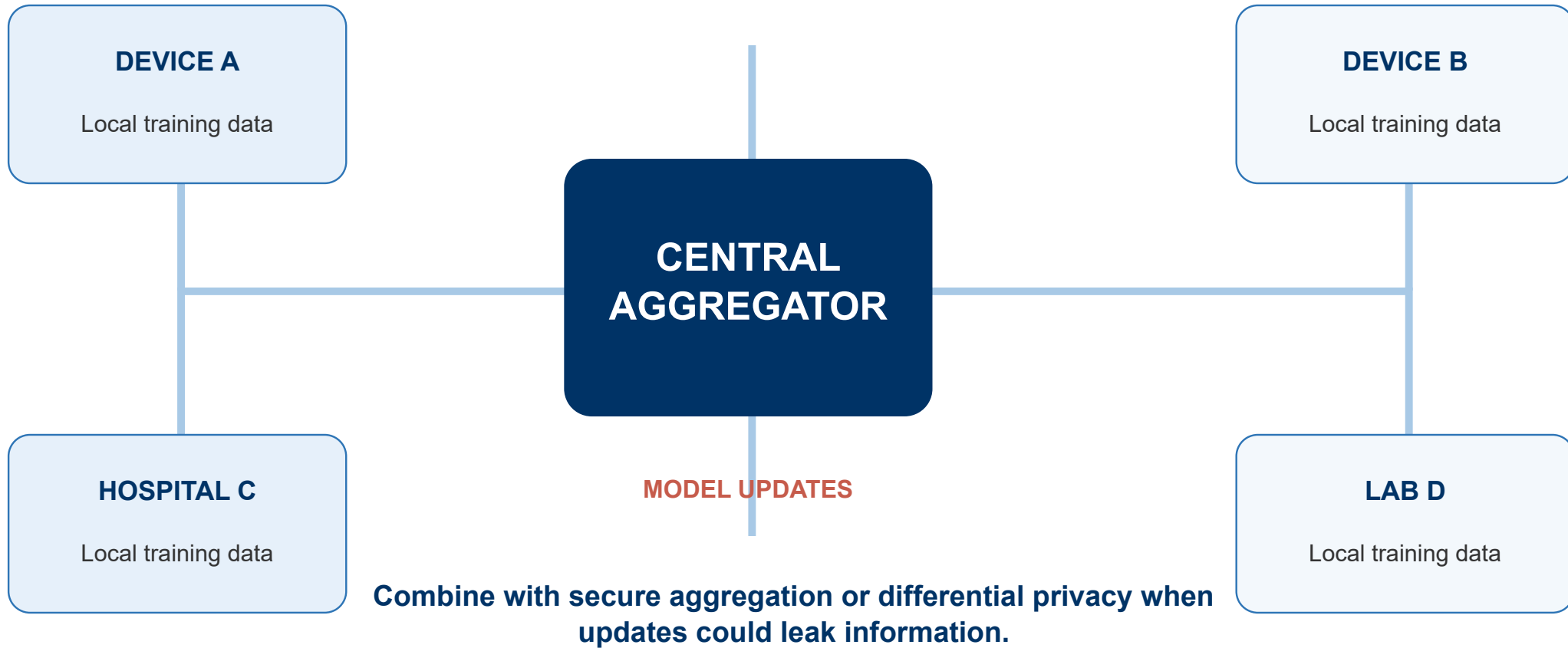
LIMIT

A small privacy budget can reduce utility. A large budget weakens protection.



A privacy budget makes the disclosure risk measurable, but parameter choices matter.

Federated learning



Keeping raw data local reduces central collection, while model updates still need protection.

Synthetic data and homomorphic encryption

SYNTHETIC DATA

Artificial records approximate selected statistical properties of source data.

Useful for testing, development, and controlled sharing
Quality depends on how well the generator preserves relevant patterns
Memorisation and bias can remain if generation lacks safeguards

HOMOMORPHIC ENCRYPTION

A service computes on encrypted data without seeing the plaintext values.

Protects confidentiality while data is in use
Suitable for selected medical and financial computations
Computation and engineering costs remain high for large workloads

Threat model first: identity exposure and data-in-use exposure require different tools.

These techniques protect different stages of use and carry different implementation costs.

PET trade-offs

PET	PRIVACY GAIN	UTILITY COST	COMPLEXITY	TYPICAL AI USE
Differential privacy	Limits individual contribution	Variable	Medium	Statistics and private training
Federated learning	Keeps raw data local	Low to medium	High	Cross-device or multi-site training
Synthetic data	Reduces direct identity exposure	Variable	Medium	Testing and controlled sharing
Homomorphic encryption	Protects data during computation	Low result loss	Very high	Selected encrypted inference
Secure MPC	Avoids pooling raw inputs	Low result loss	High	Joint analytics across organisations
Trusted environments	Isolates computation	Low	Medium to high	Protected model execution

Tool selection depends on the threat, acceptable accuracy loss, and operational capacity.

Data Protection Impact Assessment

A structured process for identifying and minimising data protection risks.

WHEN A DPIA IS REQUIRED

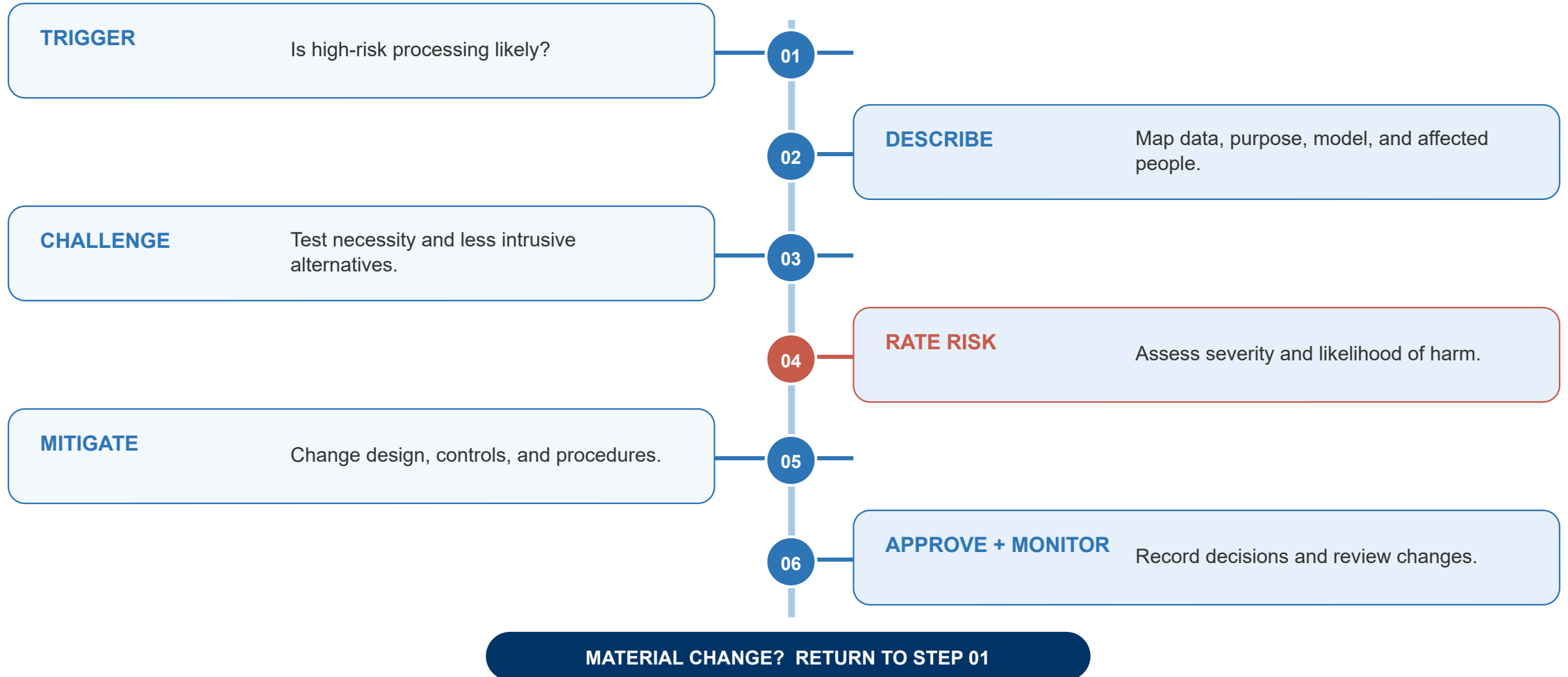
- | | | |
|----|-------------------------|---|
| 01 | EXTENSIVE PROFILING | Significant effects on people |
| 02 | SENSITIVE DATA AT SCALE | Health, biometrics, or other special categories |
| 03 | PUBLIC MONITORING | Systematic observation across public space |
| 04 | HIGH-RISK AUTOMATION | Decisions with legal or similarly significant effects |

**BEFORE
PROCESSING**

Identify
Reduce
Document

A DPIA documents risk and changes the project before high-risk processing begins.

DPIA for AI: a living risk loop



A DPIA is revisited when the data, model, purpose, people, or deployment materially changes.

EU AI Act and data protection

UNACCEPTABLE RISK

Prohibited practices apply since February 2025

TRANSPARENCY DUTIES

System and content transparency duties apply since August 2026

HIGH-RISK · ANNEX III

Requirements apply from 2 December 2027

PRODUCT-EMBEDDED HIGH RISK

Requirements apply from 2 August 2028

GDPR STILL APPLIES

Lawful basis and Article 9 conditions

Rights and transparency

DPIA for likely high-risk processing

Security, minimisation, and accountability

As of September 2026

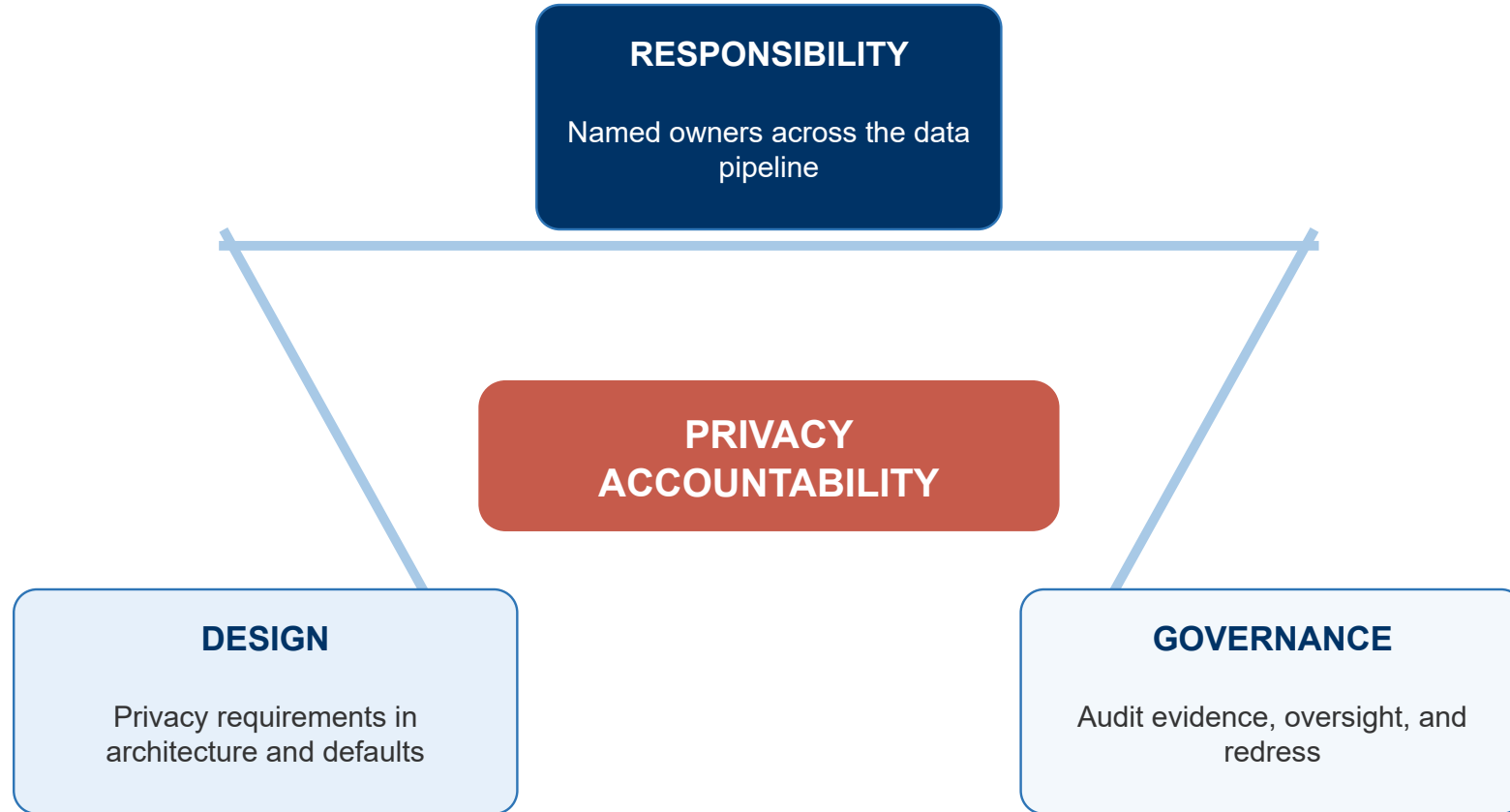
AI Act duties layer onto GDPR obligations; high-risk timelines now extend into 2027 and 2028.

Cross-jurisdictional comparison

DIMENSION	EU	UNITED STATES	CHINA
Core framework	GDPR plus AI Act	Sector laws, state laws, FTC Act §5	PIPL plus algorithm rules
Legal basis	Article 6 bases; Article 9 condition where relevant	Authority depends on sector, state, and practice	Consent and statutory alternatives under PIPL
Automated decisions	GDPR Art. 22 safeguards; AI Act duties	Case-specific federal and state rules	PIPL Art. 24 fairness, transparency, and refusal rights in specified uses
Sensitive data	GDPR Art. 9	Sector and state protections	PIPL Art. 28; separate consent generally required
Transfers	Adequacy, SCCs, or another GDPR mechanism	No single omnibus federal transfer regime	Security assessment, certification, or standard contract routes
Current AI focus	Transparency active; high-risk duties phased to 2027/2028	Agency enforcement and state legislation	Algorithm governance and personal information protection

Privacy governance differs by jurisdiction, so product controls need a clear legal map.

Privacy accountability in Responsible AI



Accountability connects organisational responsibility, system design, and independent verification.

Privacy and vulnerability

EUBANKS'S DESIGN QUESTION

Who carries the privacy burden when access to a basic service depends on data collection?

Automating Inequality (2018)

01 NO FORCED SURRENDER

Do not condition essential services on unnecessary data extraction

02 TEST UNEQUAL BURDENS

Measure who faces more surveillance and less recourse

03 REAL APPEAL

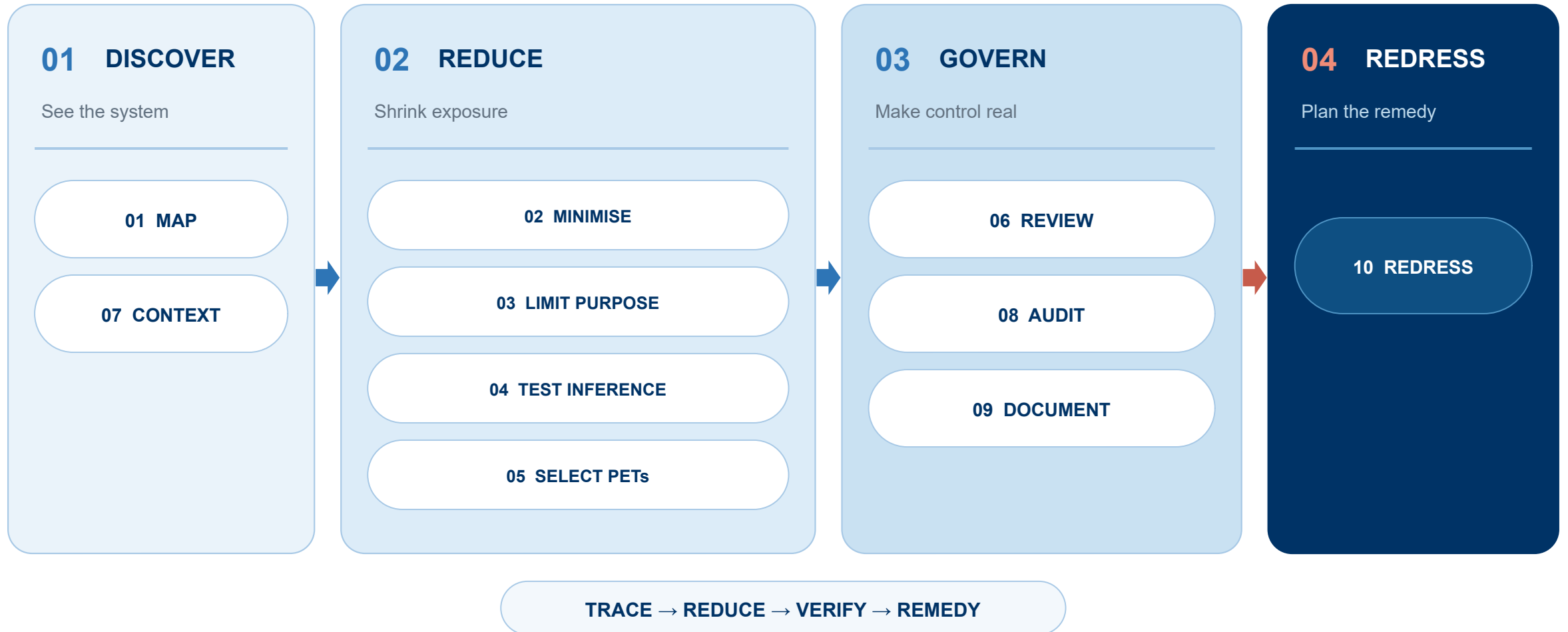
Give a reviewer authority to change the outcome

04 FAILURE-FOCUSED DESIGN

Start with the person who bears the worst plausible harm

Privacy safeguards should work for people who cannot refuse a service or absorb an error.

A privacy operating system for AI



Ten practical rules move from discovery to reduction, governance, and redress.

Mini activity: the privacy audit canvas

A PEOPLE

- ☐ Stakeholders — Who is affected?
- ☐ Rights — Can people act on them?

B DATA + PURPOSE

- ☐ Data flows — What is collected or inferred?
- ☐ Legal basis — What supports each purpose?

C CONTROLS

- ☐ PETs — Which technical control fits?
- ☐ Governance — Who owns the decision and DPIA?

D HARM + REMEDY

- ☐ Risks — What harm is plausible?
- ☐ Remedy — What happens after failure?

DELIVERABLE**Two sentences: highest risk · strongest safeguard · one unmet right****10 + 5 MIN****Work across the canvas, then compress the analysis into one actionable audit finding.**

Structured debate: privacy and utility

DIMENSION	PRIVACY ADVOCATE	UTILITY ADVOCATE
Core value	Autonomy, dignity, and limits on power	Performance, access, and public benefit
Default	Collect only what the purpose needs	Use available data when expected benefits justify it
Consent	Specific choice with an easy withdrawal path	A workable permission model at operational scale
Primary risk	Surveillance, chilling effects, and weak recourse	Missed benefit, reduced accuracy, or underperformance
Preferred remedy	Restriction, PETs, or prohibition for unacceptable uses	Transparency, audit, and proportionate opt-out

Debate prompt: which evidence would change your position?

A credible trade-off identifies who gains, who bears risk, and what evidence supports the choice.

Limits of law and governance



Durable privacy protection requires legal authority, engineering capacity, and organisational practice.

Key takeaways

01 Privacy risk accumulates from collection through inference, decisions, and retention.

02 Public availability, consent, accuracy, and security each require contextual analysis.

03 High-stakes systems need necessity tests, alternatives, and effective review.

04 Derived data and model outputs can carry risks comparable to source records.

05 Effective remedies reach data use and future system behaviour.

06 PETs provide useful guarantees when teams match them to a defined threat.

07 Vulnerable people need safeguards that work without money, time, or technical expertise.

LIFECYCLE



ACCOUNTABILITY



HUMAN IMPACT

Responsible AI treats privacy as a lifecycle duty and a question of power.

Reading, next lecture, and Q&A

READ

Coeckelbergh: chapter on privacy
Eubanks: Chapter 1
Available on Canvas

siruihan@ust.hk

Office hours: TBD

NEXT

Lecture 3

Accountability, Responsibility, Transparency

REFLECT

Name one data point you shared today that you cannot delete. Who holds it, and what would you do if it were wrong?

Questions are welcome.

Thank you!

Q&A

HKUST · MSc(AIE) Program · Fall 2026/27